Proof of Concept

- Ho realizzato un esempio step by step di come si utilizza il tool

Startup

- Ho implementato un docker compose per eseguire sia firegex che un servizio vulnerabile tramite XSS e SQLi

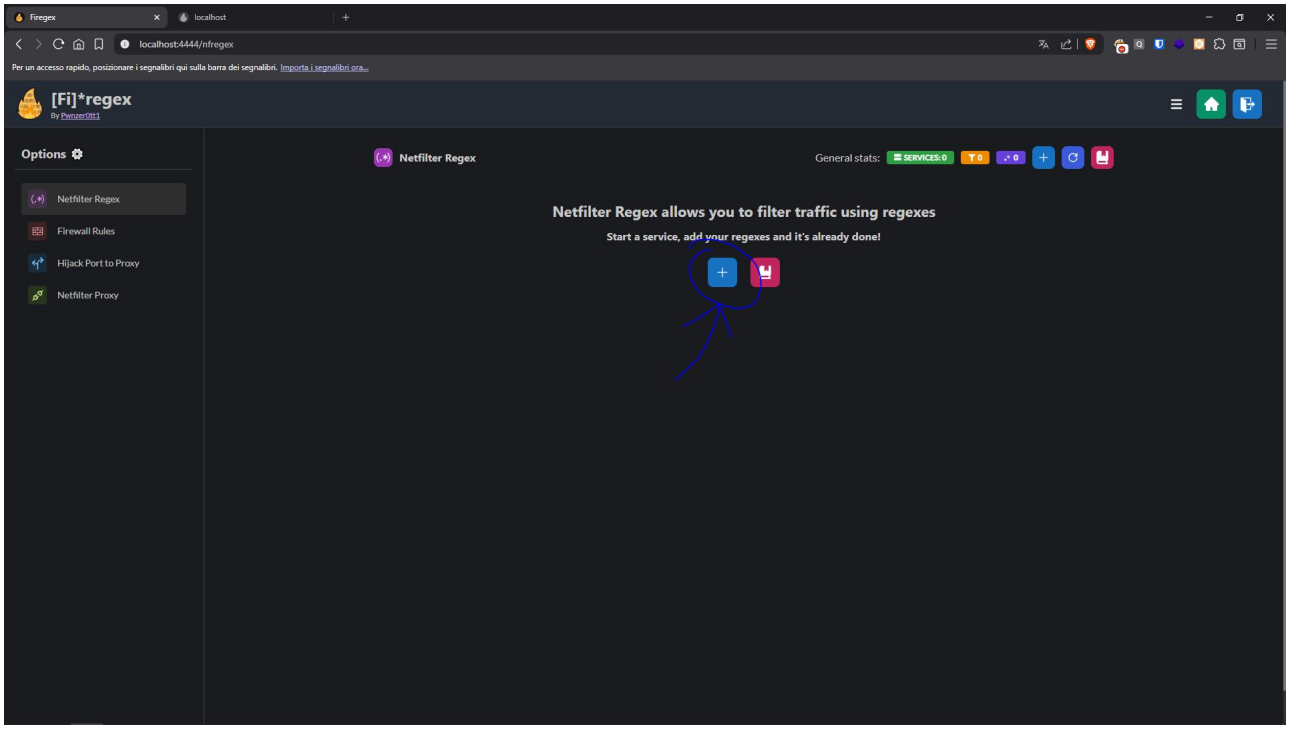
```
riny@DESKTOP-03C436B:/mnt/c/Users/~Riny/workbanch/Desktop/FIregex$ docker compose up --build
WARN[0000] /mnt/c/Users/~Riny/workbanch/Desktop/FIregex/docker-compose.yml: the attribute `version` is obsolete, it will be ignored, please remove it to avoid potential com
usion
[+] Building 0.7s (12/12) FINISHED
 => [internal] load local bake definitions                                                                                                                    0.0s
 => => reading from stdin 590B                                                                                                                                0.0s
 => [internal] load build definition from Dockerfile                                                                                                          0.0s
 => => transferring dockerfile: 204B                                                                                                                          0.0s
 => [internal] load metadata for docker.io/library/python:3.9-slim                                                                                            0.4s
 => [internal] load .dockerignore                                                                                                                             0.0s
 => => transferring context: 2B                                                                                                                               0.0s
 => [1/5] FROM docker.io/library/python:3.9-slim@sha256:2d97f6910b16bd338d3060f261f53f144965f755599aab1acda1e13cf1731b1b                                      0.0s
 => [internal] load build context                                                                                                                             0.0s
 => => transferring context: 63B                                                                                                                              0.0s
 => CACHED [2/5] WORKDIR /app                                                                                                                                 0.0s
 => CACHED [3/5] COPY requirements.txt .                                                                                                                      0.0s
 => CACHED [4/5] RUN pip install --no-cache-dir -r requirements.txt                                                                                           0.0s
```

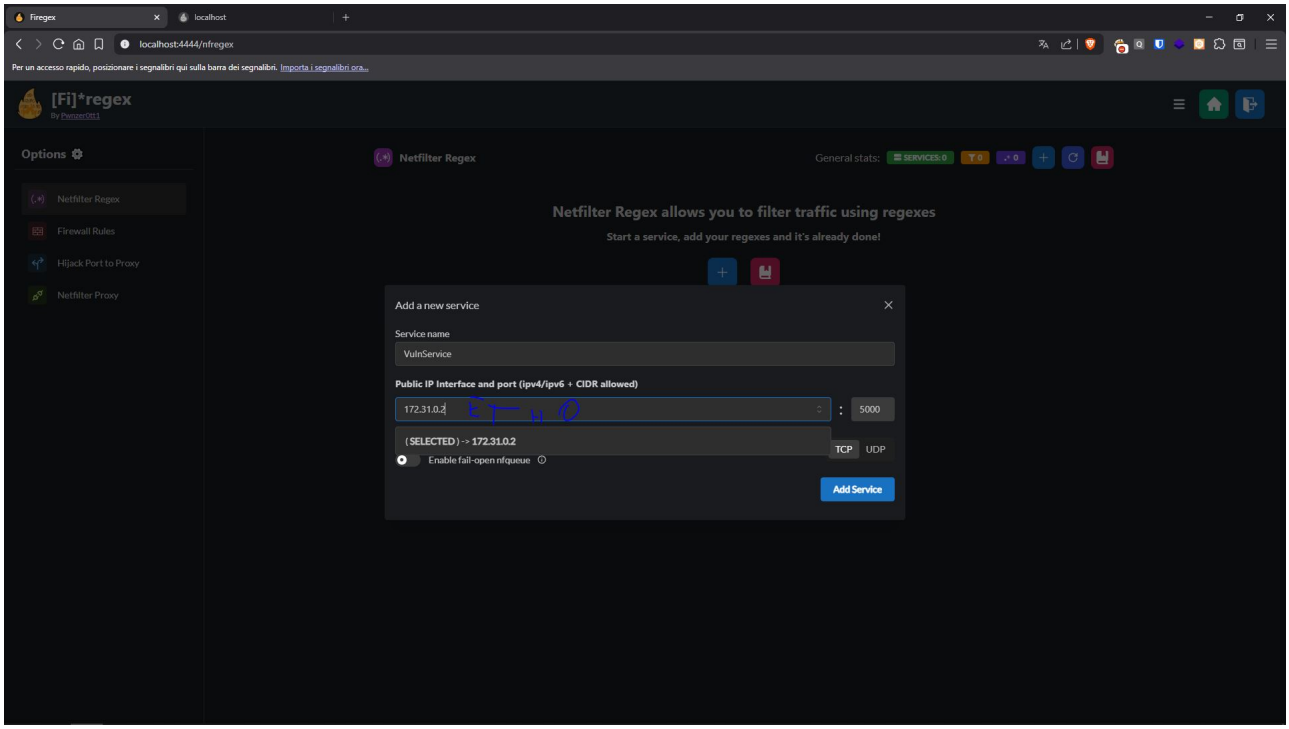
Esecuzione script per PoC delle vulnerabilità

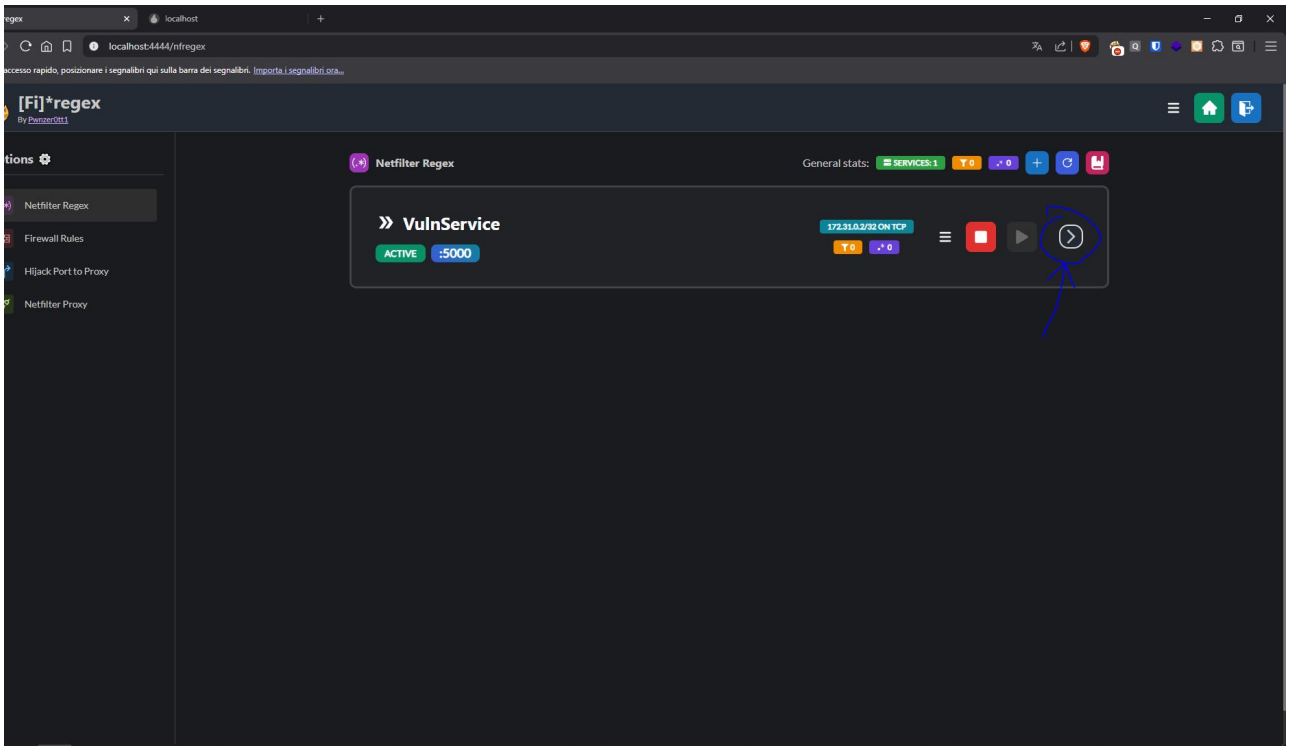
```
riny@DESKTOP-03C436B:/mnt/c/Users/~Riny/workbanch/Desktop/FIregex$ python3 exploit.py
==================================================
        Vulnerable Service Exploit PoC
==================================================
[+] Service is UP at http://127.0.0.1:5000

[+] Attempting SQL Injection on /login...
[SUCCESS] SQL Injection successful!
    Server response: Welcome, admin! (Logged in via SQLi)

[+] Attempting Reflected XSS on /search...
[SUCCESS] XSS Payload Reflected!
    Response snippet: ...<h2>Search Results</h2>
    <p>You searched for: <script>alert('XSS_SUCCESS')</script></p>...
```

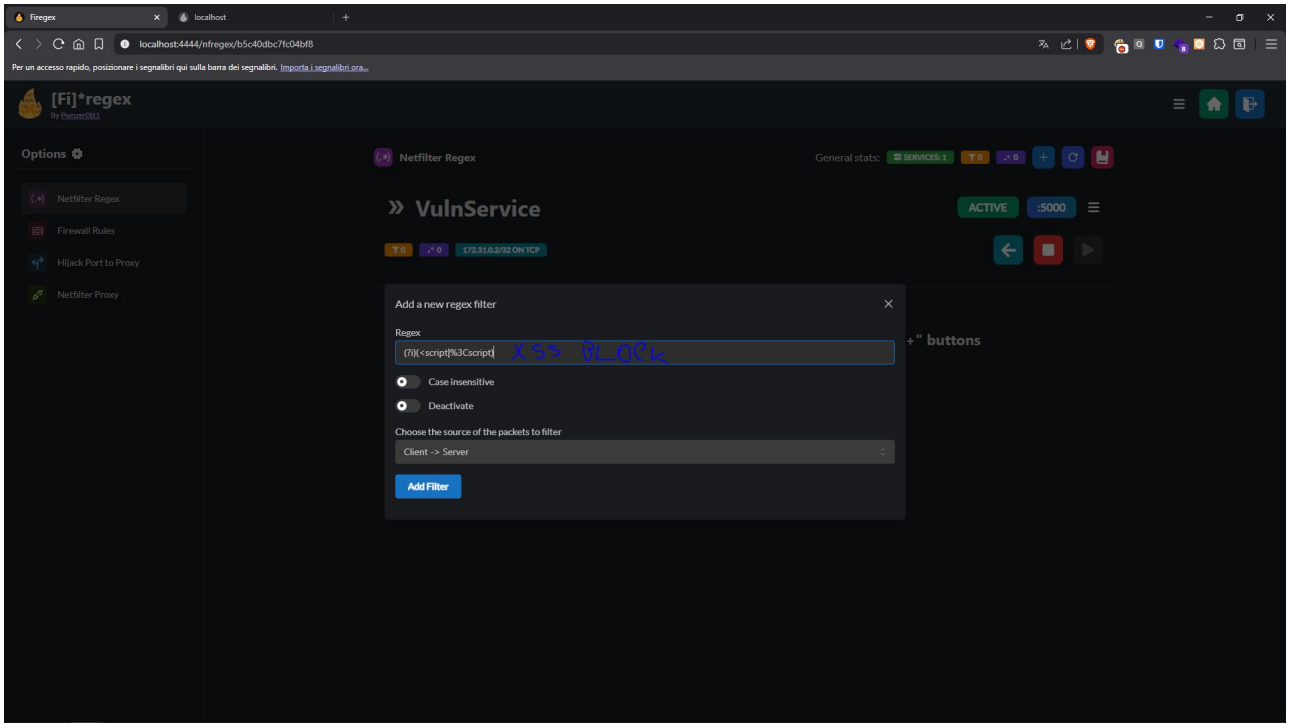
Come si presenta l'app

- Ora segue una guida Step-by-Step di come creare un filtro regex per bloccare le richieste in entrata









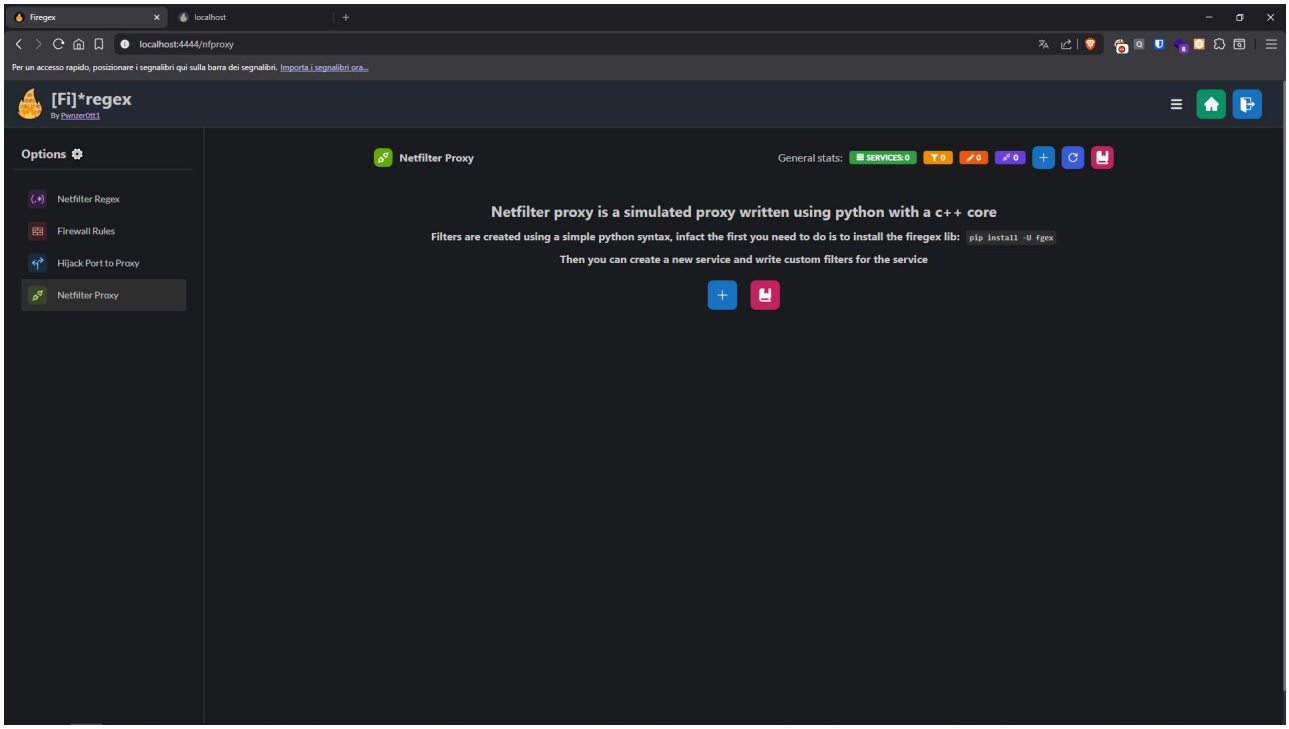
Esecuzione script dopo il blocco XSS

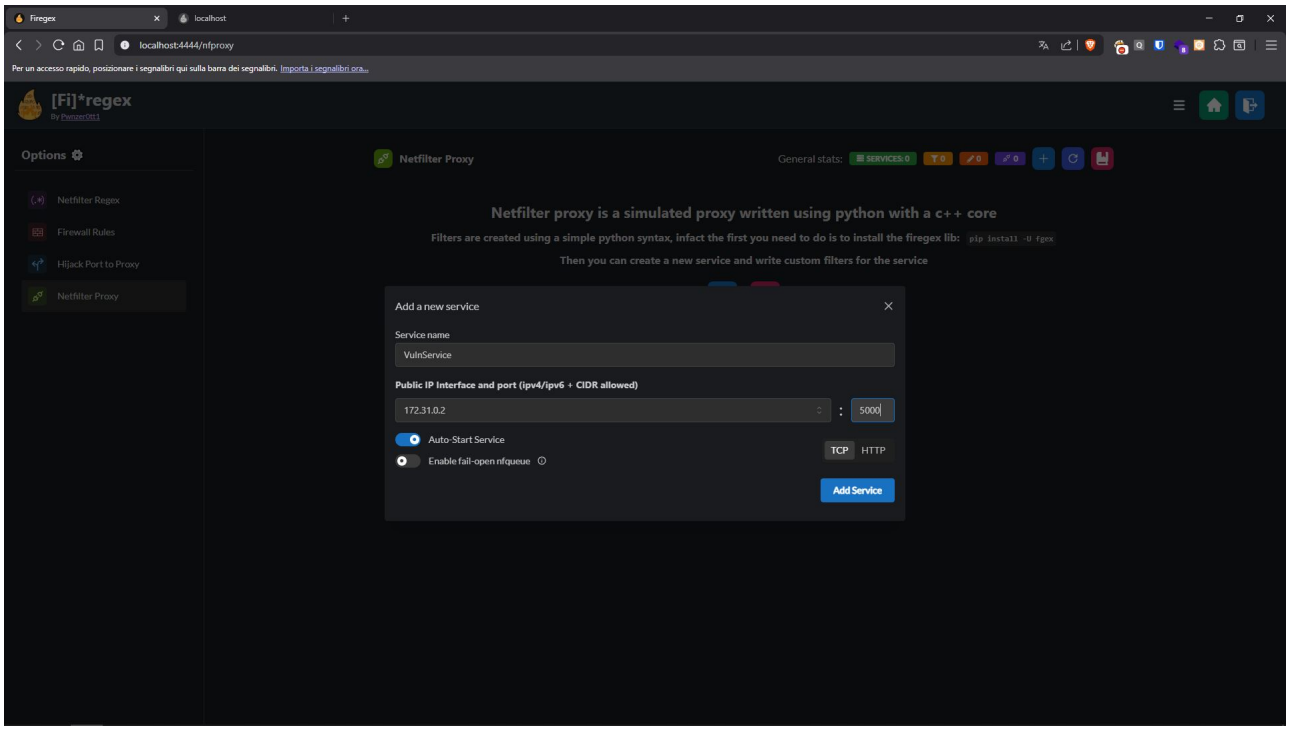
- Ciò che accade all'esecuzione dello script è un blocco della richiesta fino allo scattare del timeout

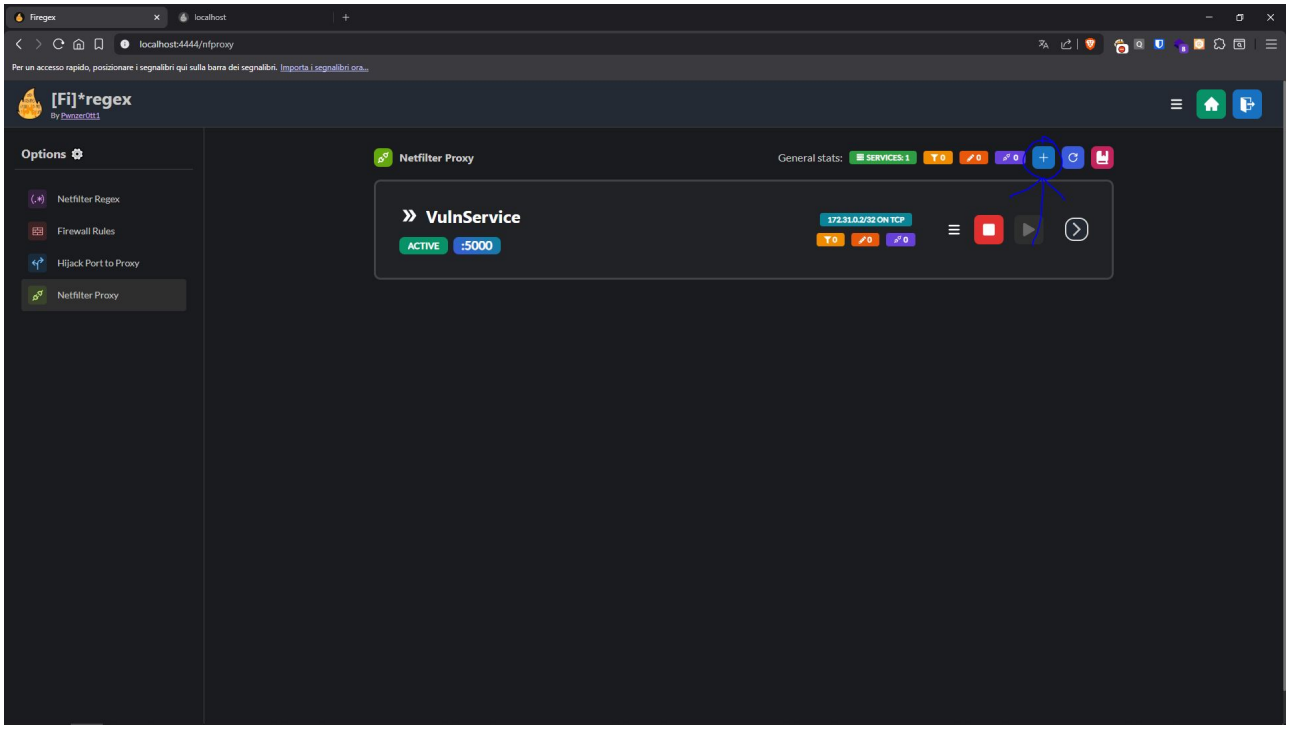
```
riny@DESKTOP-03C436B:/mnt/c/Users/~Riny/workbanch/Desktop/FIregex$ python3 exploit.py
==================================================
        Vulnerable Service Exploit PoC
==================================================
[+] Service is UP at http://127.0.0.1:5000

[+] Attempting SQL Injection on /login...
[SUCCESS] SQL Injection successful!
    Server response: Welcome, admin! (Logged in via SQLi)

[+] Attempting Reflected XSS on /search...
```

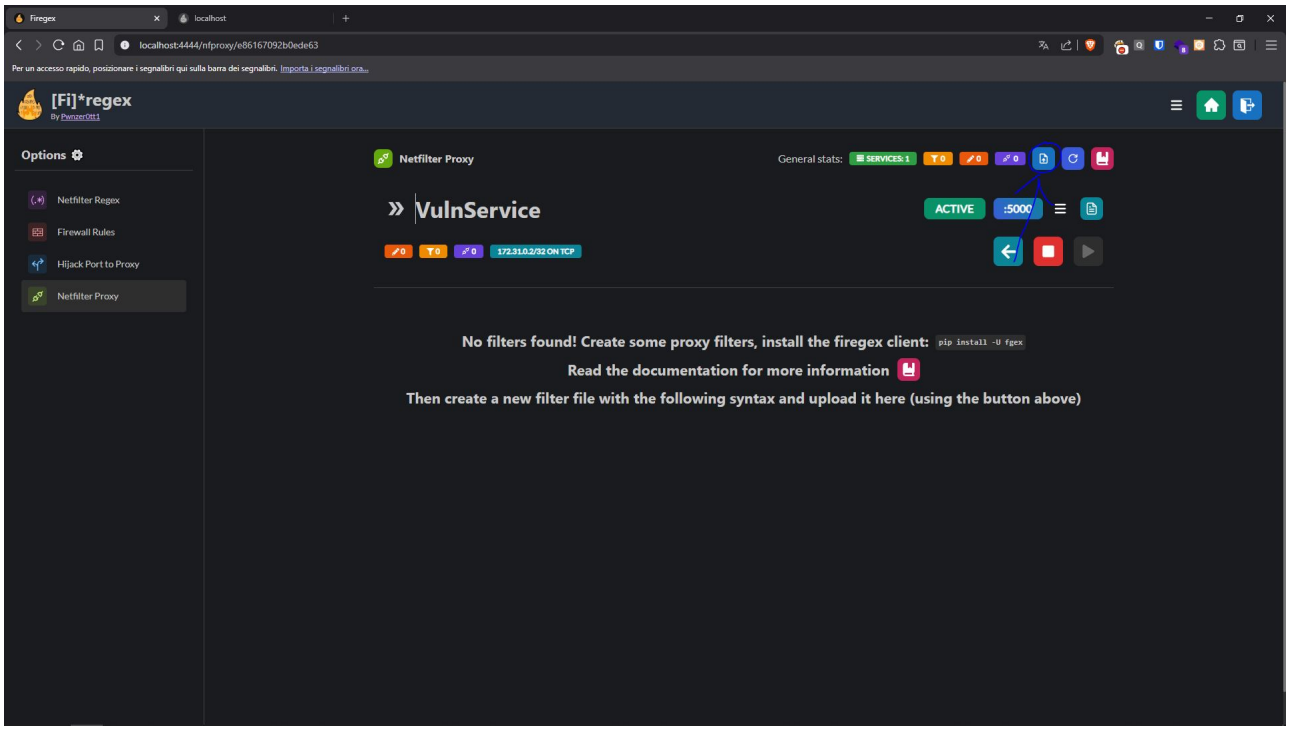
Implementare una regola tramite script python

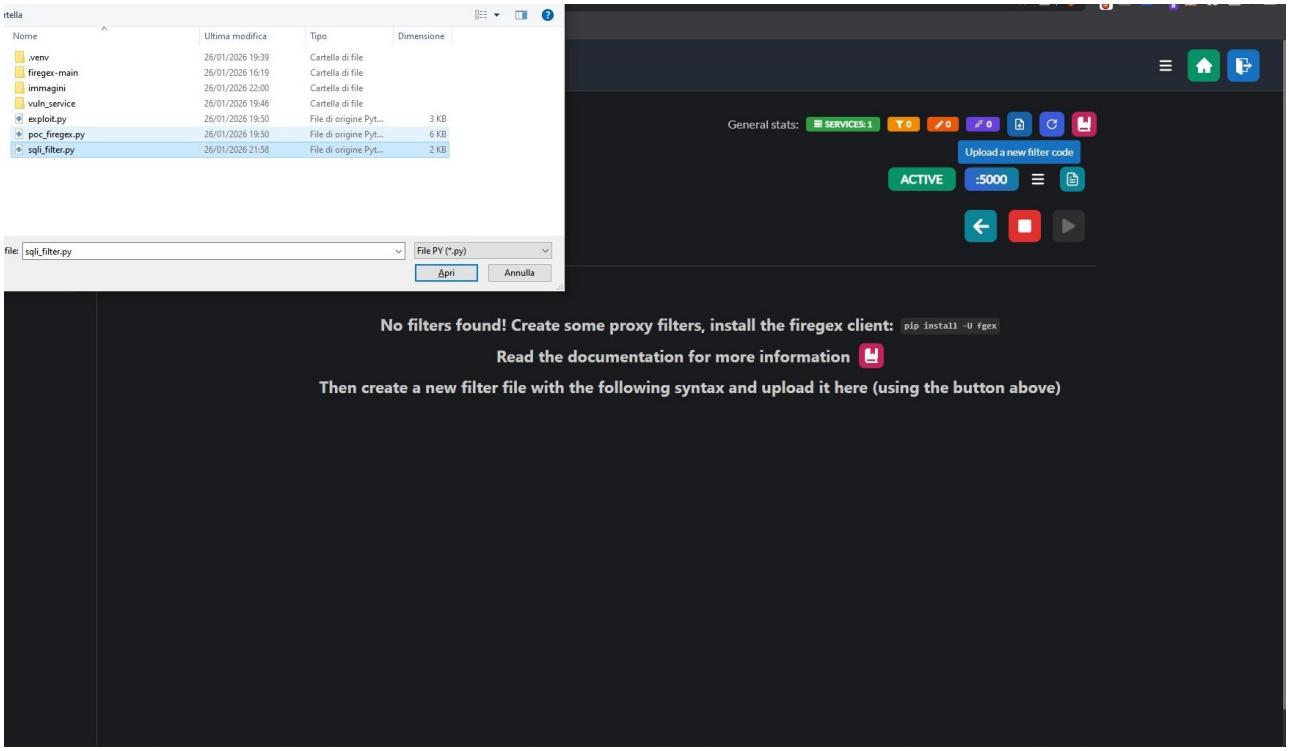
- Firegex permette di filtrare il traffico tramite script in python
- Guida step-by-step sul filtraggio su pattern

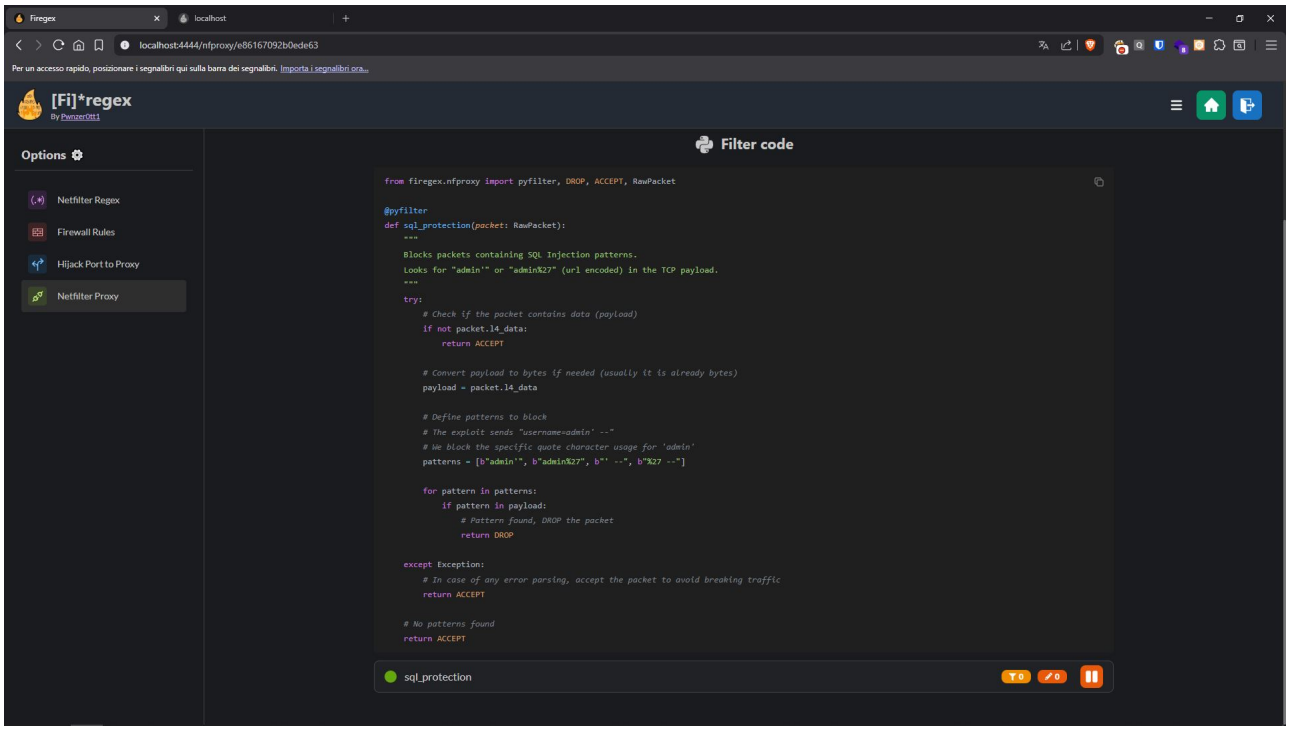


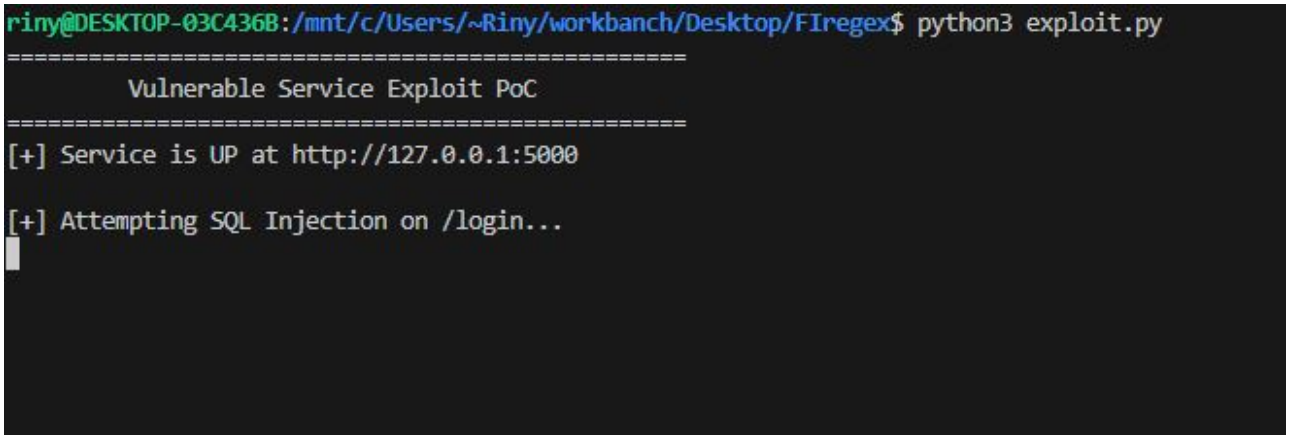

Firegex
localhost
localhost:4444/nfproxy
Per un accesso rapido, posizionare i segnalibri qui sulla barra dei segnalibri. Importa i segnalibri ora...
[Fi]*regex
By PwnzerOtt1
Options
Netfilter Regex
Firewall Rules
Hijack Port to Proxy
Netfilter Proxy
Netfilter Proxy
General stats:
SERVICES: 0
Netfilter proxy is a simulated proxy written using python with a c++ core
Filters are created using a simple python syntax, infact the first you need to do is to install the firegex lib: pip install -U fgex
Then you can create a new service and write custom filters for the service
Add a new service
Service name
VulnService
Public IP Interface and port (ipv4/ipv6 + CIDR allowed)
172.31.0.2
5000
Auto-Start Service
Enable fail-open nfqueue
TCP
HTTP
Add Service


Firegex
localhost
localhost:4444/nfproxy
Per un accesso rapido, posizionare i segnalibri qui sulla barra dei segnalibri. Importa i segnalibri ora...
[Fi]*regex
By PwnzerOtt1
Options
Netfilter Regex
Firewall Rules
Hijack Port to Proxy
Netfilter Proxy
Netfilter Proxy
General stats:
SERVICES: 1
VulnService
ACTIVE
:5000
172.31.0.2/32 ON TCP


Firegex
localhost
localhost:4444/nfproxy/e86167092b0ede63
Per un accesso rapido, posizionare i segnalibri qui sulla barra dei segnalibri. Importa i segnalibri ora...
[Fi]*regex
By PwnzerOtt1
Options
Netfilter Regex
Firewall Rules
Hijack Port to Proxy
Netfilter Proxy
Netfilter Proxy
General stats:
SERVICES: 1
VulnService
ACTIVE
:5000
172.31.0.2/32 ON TCP
No filters found! Create some proxy filters, install the firegex client:
pip install -U fgex
Read the documentation for more information
Then create a new filter file with the following syntax and upload it here (using the button above)


Nome
Ultima modifica
Tipo
Dimensione
.venv
26/01/2026 19:39
Cartella di file
firegex-main
26/01/2026 16:19
Cartella di file
immagini
26/01/2026 22:00
Cartella di file
vuln_service
26/01/2026 19:46
Cartella di file
exploit.py
26/01/2026 19:50
File di origine Pyt...
3 KB
poc_firegex.py
26/01/2026 19:50
File di origine Pyt...
6 KB
sqli_filter.py
26/01/2026 21:58
File di origine Pyt...
2 KB
File: sqli_filter.py
File PY (*.py)
Apri
Annulla
General stats:
SERVICES: 1
Upload a new filter code
ACTIVE
:5000
No filters found! Create some proxy filters, install the firegex client:
pip install -U fgex
Read the documentation for more information
Then create a new filter file with the following syntax and upload it here (using the button above)


Firegex
localhost
localhost:4444/nfproxy/e86167092b0ede63
Per un accesso rapido, posizionare i segnalibri qui sulla barra dei segnalibri. Importa i segnalibri ora...
[Fi]*regex
By PwnzerOtt1
Options
Netfilter Regex
Firewall Rules
Hijack Port to Proxy
Netfilter Proxy
Filter code
from firegex.nfproxy import pyfilter, DROP, ACCEPT, RawPacket
@pyfilter
def sql_protection(packet: RawPacket):
"""
Blocks packets containing SQL Injection patterns.
Looks for "admin'" or "admin%27" (url encoded) in the TCP payload.
"""
try:
# Check if the packet contains data (payload)
if not packet.l4_data:
return ACCEPT
# Convert payload to bytes if needed (usually it is already bytes)
payload = packet.l4_data
# Define patterns to block
# The exploit sends "username=admin' --"
# We block the specific quote character usage for 'admin'
patterns = [b"admin'", b"admin%27", b"' --", b"%27 --"]
for pattern in patterns:
if pattern in payload:
# Pattern found, DROP the packet
return DROP
except Exception:
In case of any error parsing, accept the packet to avoid breaking traffic
return ACCEPT
No patterns found
return ACCEPT
sql_protection


riny@DESKTOP-03C436B:/mnt/c/Users/~Riny/workbanch/Desktop/FIregex$ python3 exploit.py
==========
Vulnerable Service Exploit PoC
==========
[+] Service is UP at http://127.0.0.1:5000
[+] Attempting SQL Injection on /login...